

DESENVOLVIMENTO DE SOFTWARE SEGURO · PROF. RANYERE LIMA

FALHAR COM SEGURANÇA

O princípio **fail-safe**: quando o sistema quebra, ele tem que quebrar **fechado**, nunca aberto.

Cauê Lima e grupo · Turma 3001 · Martha Falcão Wyden

O PRINCÍPIO

Quando algo dá errado, o sistema erra fechando

Uma falha, rede fora, serviço travado, exceção inesperada, **nunca pode terminar em acesso liberado ou dado vazado**. Na dúvida, o sistema nega.

POR QUE ISSO IMPORTA

A falha é inevitável. O comportamento na falha é uma escolha.

Rede cai

e a sessão continua válida sem ninguém verificar

Erro estoura

e a tela mostra o stack trace com detalhes do banco

Catch vazio

engole a exceção e o fluxo segue como se tivesse passado

Resultado

o atacante não quebra a segurança, ele só provoca o erro

EXEMPLO APLICADO • APP BANCÁRIO

Serviço de sessão fora do ar. E agora?



Ficar indisponível por um momento é melhor do que **aprovar uma transferência sem verificação**.

DEMO • API DE PAGAMENTO COM ANTIFRAUDE FORA DO AR

Fail-open vs fail-closed

✗ COMO NÃO FAZER (FAIL-OPEN)

aguardando...

✓ FALHANDO COM SEGURANÇA (FAIL-CLOSED)

aguardando...

Simular queda do antifraude

Resetar

Fail-open vs fail-closed

✗ COMO NÃO FAZER (FAIL-OPEN)

POST /pagamento R\$ 4.900,00

✓ FALHANDO COM SEGURANÇA (FAIL-CLOSED)

POST /pagamento R\$ 4.900,00

Simular queda do antifraude

Resetar

O ERRO CLÁSSICO

"Aprova aí, é só pra não travar as vendas"

A API que aprova transações quando o antifraude está fora do ar cria uma janela onde **toda fraude passa**. E o atacante consegue provocar essa janela: basta sobrecarregar o antifraude.

Negação por padrão, sempre

Default deny

toda decisão de acesso
começa negada e é liberada
explicitamente

Catch que nega

tratamento de erro registra no
log e recusa, nunca aprova

Timeout = recusa

dependência que não
responde é tratada como
negativa

Mensagem genérica

o usuário vê "algo deu errado",
o detalhe técnico fica no log

Fault injection

testar o sistema derrubando as
dependências de propósito

FECHANDO

Funcionar não é ser seguro

O sistema escolar da aula funciona perfeitamente e deixa o aluno alterar a própria nota. Software seguro é o que se comporta bem **inclusive no pior dia**, quando tudo à volta está falhando.

Obrigado! · Falhar com Segurança · Desenvolvimento de Software Seguro